

SRI SIVASUBRAMANIYA NADAR COLLEGE OF ENGINEERING

Kalavakkam, Chennai – 603110

(An Autonomous Institution Affiliated to Anna University)

Department of Computer Science and Engineering

ASSIGNMENT REPORT

Topic

Case Study on Penetration Testing Using the Ethical Hacking Process based on
Rules of Engagement

Name	BOOBATHI V
Register Number	3122245001032
Class	CSE – Section A
Degree	B.E. Computer Science and Engineering
Subject	Ethical Hacking

TABLE OF CONTENTS

Abstract

1. Introduction

- 1.1 Ethical Hacking
- 1.2 Penetration Testing
- 1.3 Rules of Engagement
- 1.4 Types of Pen Testing
- 1.5 Pen Testing Life Cycle
- 1.6 Importance in Universities

2. Organization Overview

3. Scope of Penetration Testing

4. Rules of Engagement

5. Ethical Hacking Methodology

6. Reconnaissance

7. Scanning and Enumeration

8. Vulnerability Analysis

9. Controlled Exploitation

10. Post Exploitation

11. Reporting

12. Penetration Testing Questionnaire

13. Security Recommendations

14. Risk Assessment Matrix

15. Best Practices

16. Conclusion

LIST OF TABLES

Table 1 Critical Assets

Table 2 In Scope

Table 3 Out of Scope

Table 4 ROE Timeline

Table 5 Communication Plan

Table 6 Methodology

Table 7 Recon Tools

Table 8 Port Scan

Table 9 Vulnerabilities

Table 10 CVSS Ratings

Table 11 Risk Matrix

Table 12 Recommendations

Table 13 Questionnaire

ABSTRACT

The rising tide of cyber attacks targeting educational institutions has made proactive security measures essential for colleges and universities. This assignment presents a penetration

testing case study conducted at Sri Sivasubramaniya Nadar (SSN) College of Engineering, Chennai. The campus network serves over four thousand students and two hundred faculty members, supporting critical services including the student portal, ERP system, Moodle LMS, and institutional email infrastructure.

The engagement followed a structured ethical hacking process spanning planning, reconnaissance, scanning, vulnerability analysis, controlled exploitation, post-exploitation, and reporting. All activities were governed by a detailed Rules of Engagement document that defined authorized targets, testing windows, permitted techniques, and prohibited actions. Written authorization was obtained from the institutional administration before any testing commenced, as unauthorized access constitutes an offense under the Information Technology Act, 2000 regardless of intent.

Tools employed included Nmap, Nikto, theHarvester, Shodan, Maltego, and Gobuster within a controlled testing environment. Findings were rated using the Common Vulnerability Scoring System (CVSS) and mapped to the MITRE ATT&CK framework. Twelve vulnerabilities were identified, from critical SQL injection flaws in the student portal to lower-severity gaps such as missing HTTP security headers. The overall risk posture was assessed as high. Twenty prioritized recommendations conclude the report, targeting reduction of the institution's cyber threat exposure.

Keywords: Ethical Hacking, Penetration Testing, Rules of Engagement, Vulnerability Assessment, Network Security, OSINT, Nmap, OWASP

1. INTRODUCTION

1.1 Ethical Hacking

Ethical hacking refers to probing computer systems for security weaknesses with explicit permission from the system owner. Unlike malicious actors, ethical testers operate within a framework of legal authorization and professional responsibility. The practice gained prominence in the late 1990s when companies like IBM began offering security assessment services. Today it is governed by standards including NIST SP 800-115, the Penetration Testing Execution Standard (PTES), and the OWASP Testing Guide.

An ethical hacker must think like an attacker: understanding how reconnaissance feeds exploitation, how small misconfigurations escalate into full compromises, and how human

factors often prove more dangerous than software bugs. The distinction from criminal hackers lies entirely in intent and authorization, not in tools or techniques.

1.2 Penetration Testing

Penetration testing actively exploits identified weaknesses rather than simply cataloging them. Where a scanner might flag a potential SQL injection, a pen tester crafts an actual payload to demonstrate real impact. This provides a realistic picture of defenses rather than a theoretical vulnerability list.

The value of a penetration test lies in what it proves, not just what it finds. A verified proof of concept tells the institution exactly how an attacker would proceed, what data could be reached, and how much time and skill the attack requires. This turns an abstract risk register into a concrete, prioritized remediation plan that security teams can actually execute.

A pen test progresses through planned stages: planning, reconnaissance, scanning, vulnerability analysis, exploitation, post-exploitation, and reporting. Three approaches exist based on tester knowledge. Black-box simulates an outside attacker with zero prior information. White-box provides complete transparency with code and credentials. Gray-box gives partial knowledge, typically a user login, and is the most common choice for university assessments due to its balance of realism and efficiency.

1.3 Rules of Engagement

The ROE is the governance document defining authorized systems, testing windows, allowed techniques, communication protocols, and prohibited activities. Without a clear ROE, even well-intentioned testing crosses legal boundaries. This assignment includes a detailed ROE for the SSN campus network engagement, jointly prepared and signed before any testing began.

1.4 Penetration Testing Life Cycle

Phase 1 - Planning: Define objectives, sign ROE, establish encrypted communications. Phase 2 - Reconnaissance: Gather intelligence through OSINT and active probing. Phase 3 - Scanning: Identify hosts, ports, and running services. Phase 4 - Vulnerability Analysis: Cross-reference services against known CVEs. Phase 5 - Controlled Exploitation: Validate findings with pre-approved payloads. Phase 6 - Post Exploitation: Assess access depth and lateral movement potential. Phase 7 - Reporting: Compile findings into an actionable document.

1.5 Importance in Universities

Campus networks present unique security challenges: students bring personal devices, faculty demand open research access, and administrators manage sensitive data. All runs on infrastructure spanning decades-old systems to modern deployments. A breach in the student information system could expose thousands of records containing names, addresses, and academic histories. Regular penetration testing helps institutions identify and remediate weaknesses before adversaries discover them.

2. ORGANIZATION OVERVIEW

SSN College of Engineering, located in Kalavakkam along the East Coast Road in Chennai, is an autonomous institution affiliated with Anna University. Established under the SSN Trust, the campus spans roughly 100 acres and houses academic blocks, research laboratories, hostels, a central library, and a fully networked IT infrastructure serving approximately 200 faculty, 350 support staff, and over 4,000 students across seven engineering departments.

2.1 Network Architecture

The campus network uses a three-tier hierarchical design with core, distribution, and access layers built on Cisco Catalyst switches. Multiple ISP connections provide internet redundancy. The firewall handles perimeter filtering. Internal DNS resolves names for all services. Email runs on Postfix with Dovecot. VMware ESXi hosts the major applications in a centralized data center with automated nightly backups.

Key services include the student portal (attendance, results, fees), faculty portal (grades, leave), ERP (admissions, accounts, HR), Moodle LMS (course materials, quizzes), VPN gateway (remote access), and campus Wi-Fi using WPA2-Enterprise with RADIUS authentication plus a separate guest network.

S.No	Asset	Description	Criticality
1	Student Portal	Academic records, attendance	High
2	Faculty Portal	Grade submission, leave mgmt	High
3	ERP System	Admin operations, accounts	Critical
4	Moodle LMS	Course materials, assessments	High

5	Email Server	Postfix/Dovecot email	High
6	DNS Server	Name resolution	Critical
7	Wi-Fi Network	WPA2-Enterprise wireless	Medium
8	Firewall	Perimeter security	Critical
9	Database Servers	Student/financial data	Critical
10	Cloud Services	AWS/Azure applications	High

3. SCOPE OF PENETRATION TESTING

Defining scope prevents both incomplete coverage and unauthorized overreach. For SSN, the scope was finalized through three rounds of discussion between the testing team and IT administration.

S.No	Target	Type
1	Public Website (ssn.edu.in)	External Black-Box
2	VPN Gateway	External Black-Box
3	Campus Wi-Fi	Internal Gray-Box
4	Email Server	External Black-Box
5	DNS Server	External/Internal
6	Student Portal	External Gray-Box
7	Faculty Portal	External Gray-Box
8	ERP System	Internal White-Box
9	API Gateway	External Gray-Box
10	Cloud Dashboard	Internal White-Box

Out of scope: database deletion, physical attacks, social engineering, DoS/DDoS, employee personal devices, production data modification, vendor systems, physical tampering, wireless deauthentication, and credential brute-forcing against production accounts. Each exclusion was documented to prevent misunderstandings during testing.

The split between black-box, gray-box, and white-box testing reflects how much internal information the team was given for each target. Externally reachable services were tested blind, as an outside attacker would encounter them, while internal systems were tested with limited credentials to model a compromised insider or a Wi-Fi intruder. The ERP and cloud dashboard were white-box because their complexity made black-box scanning impractical and noisy.

Every in-scope target was assigned to one of the four testing types, and no test crossed into an excluded category. Where a potential issue touched both an in-scope and an out-of-scope

system, the team flagged it in the report but did not pursue it actively, keeping the engagement entirely within the documented authorization.

4. RULES OF ENGAGEMENT

The ROE is a formal agreement covering thirteen sections that govern every action during the engagement. It was jointly prepared and signed before testing began.

4.1 Objective and Scope

The goal is to identify and validate vulnerabilities across the campus network and web applications, assess real-world impact, and provide actionable remediation guidance. Scope matches the In Scope targets in Section 3.

4.2 Timeline and Testing Window

Phase	Duration	Days
Planning & Recon	5 Days	Day 1-5
Scanning	5 Days	Day 6-10
Vulnerability Analysis	5 Days	Day 11-15
Exploitation	7 Days	Day 16-22
Post Exploitation	3 Days	Day 23-25
Reporting	5 Days	Day 26-30

Active testing runs off-peak: weekdays 10 PM to 6 AM IST, weekends 8 AM to 10 PM IST.

Passive recon has no time restrictions. Deviations require advance approval.

4.3 Communication Plan

Type	Channel	Frequency
Daily Update	Encrypted Email	Daily by 8 AM
Weekly Report	Secure Portal	Fridays
Critical Alert	Phone + Email	Immediate
Final Delivery	Encrypted Drive	Day 30

4.4 Prohibited Activities

- DoS/DDoS attacks
- Data destruction
- Production data modification
- Out-of-scope access without approval
- Social engineering without authorization

- Physical intrusion
- Destructive payloads
- Wireless deauth attacks
- Production credential brute-forcing
- Unnecessary data exfiltration

4.5 Legal Authorization

Authorized in writing by SSN administration under the IT Act, 2000. Signed Authorization Letter and NDA on file. All team members carry proof of authorization.

5. ETHICAL HACKING METHODOLOGY

The methodology follows PTES and OWASP guidelines adapted to SSN's campus context. Seven phases structure the work, each with defined objectives and deliverables.

Phase	Objective	Key Tools
Planning	Define scope, sign ROE	Project tools
Recon	Gather intelligence	theHarvester, Shodan
Scanning	Map attack surface	Nmap, Nikto
Vuln Analysis	Find weaknesses	OWASP ZAP, Burp
Exploitation	Validate impact	Metasploit
Post-Exploitation	Assess depth	Enum tools
Reporting	Document findings	Templates

The planning phase is the most safety-critical because it fixes the boundaries of the exercise before any active technique is used. Scope, timing, and authorized targets are locked in the Rules of Engagement, and any deviation mid-engagement requires written approval from the institution's designated contact.

Reconnaissance and scanning can be performed largely in parallel across the agreed target list, but findings are not acted on until the vulnerability analysis phase confirms they are genuine. This separation of phases prevents the team from chasing false positives and keeps the effort traceable to documented evidence, which is essential for a defensible final report.

6. RECONNAISSANCE

Recon sets the foundation for everything that follows. Poor intelligence means missed subdomains, overlooked services, and vulnerabilities that never surface.

6.1 WHOIS Lookup

WHOIS queries reveal domain registration details including registrant information, name servers, and key dates. This is a passive, low-risk reconnaissance technique.

Command + WHOIS Output:

```
whois ssn.edu.in

Domain Name: ssn.edu.in
Registrar: INRegistry
Name Server: ns1.ssn.edu.in
Name Server: ns2.ssn.edu.in
Creation Date: 2003-06-20
```

6.2 DNS Enumeration

DNS enumeration discovers subdomains, mail servers, and tests for zone transfers that could expose the entire DNS database.

DNS Enumeration Commands:

```
dig ssn.edu.in ANY
dnsenum ssn.edu.in --enum
dig axfr ssn.edu.in @ns1.ssn.edu.in
```

DNS Enumeration Output:

```
dnsenum ssn.edu.in
Host's addresses:
  ssn.edu.in ..... 203.0.113.1
Name Servers:
  ns1.ssn.edu.in ..... 203.0.113.2
  ns2.ssn.edu.in ..... 203.0.113.3
Brute Force with /usr/share/wordlists/dnsmap.txt:
  portal.ssn.edu.in ..... 203.0.113.10
  moodle.ssn.edu.in ..... 203.0.113.20
  mail.ssn.edu.in ..... 203.0.113.30
Zone Transfer:
  Server ns1.ssn.edu.in is AXFR blocked (good)
```

6.3 Google Dorking

Advanced Google search operators uncover sensitive files and pages that the institution did not intend to expose to the public.

Google Dork Queries:

```
site:ssn.edu.in filetype:pdf
site:ssn.edu.in inurl:login
site:ssn.edu.in intitle:"index of"
```

Google Dork Results:

```

site:ssn.edu.in filetype:pdf
-> /docs/academic-calendar-2026.pdf
-> /media/syllabus-cse.pdf
site:ssn.edu.in inurl:login
-> /student-portal/login.php
-> /admin/login.aspx
site:ssn.edu.in intitle:"index of"
-> /uploads/ (open directory listing)

```

6.4 OSINT and Subdomain Enumeration

OSINT pulls information from social media, job postings, and public records. theHarvester aggregates email addresses and subdomains from multiple sources.

theHarvester Command + Output:

```

theHarvester -d ssn.edu.in -b all

Emails:
  admin@ssn.edu.in
  info@ssn.edu.in
  hod.cse@ssn.edu.in

Subdomains:
  portal.ssn.edu.in -> 203.0.113.10
  moodle.ssn.edu.in -> 203.0.113.20
  mail.ssn.edu.in -> 203.0.113.30
  erp.ssn.edu.in -> 203.0.113.40

```

Tool	Purpose	Type
WHOIS	Domain lookup	Passive
theHarvester	Email/subdomain harvest	Passive
Shodan	Internet device search	Passive
Maltego	Link analysis	Passive/Active
Google Dorks	Advanced search	Passive
dnsenum	DNS enumeration	Active
dig	DNS queries	Active

7. SCANNING AND ENUMERATION

Scanning moves to active interaction, mapping hosts, ports, services, and versions to build a complete attack surface inventory.

7.1 Nmap Scanning

Nmap handles host, port, and service enumeration. The command set below covers host discovery, service version detection, and vulnerability scripts.

Nmap Commands:

```

nmap -sS -T4 -p- 203.0.113.0/24
nmap -sV -sC -O -p 22,80,443,3306 203.0.113.10
nmap -A -T4 --script=vuln 203.0.113.10

```

Nmap service version scan on the portal host returned the following open ports and running services:

Nmap Service Version Output:

```

Nmap 7.93 scan report for 203.0.113.10
Host is up (0.0023s latency).
Not shown: 995 filtered tcp ports
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.4p1 Ubuntu
80/tcp open http Apache/2.4.51 (Ubuntu)
443/tcp open ssl/http Apache/2.4.51 (Ubuntu)
3306/tcp open mysql MySQL 8.0.28
8080/tcp open http Apache Tomcat/9.0.52

```

Host	Port	Service	Version
203.0.113.10	22	SSH	OpenSSH 8.4
203.0.113.10	80	HTTP	Apache/2.4.51
203.0.113.10	443	HTTPS	Apache/2.4.51
203.0.113.10	3306	MySQL	MySQL 8.0.28
203.0.113.20	80	HTTP	Apache/2.4.51
203.0.113.20	443	HTTPS	nginx/1.20.1
203.0.113.30	25	SMTP	Postfix 3.6
203.0.113.40	80	HTTP	Apache/2.4.51

7.2 Web Scanning (Nikto)

Nikto scans the web server for outdated software, dangerous files, and misconfigurations. Gobuster brute-forces directories to find hidden files and admin panels not linked from the main pages.

Nikto Command:

```
nikto -h https://portal.ssn.edu.in
```

Nikto Output:

```

- Nikto v2.1.6
+ Target: portal.ssn.edu.in (203.0.113.10)
+ Server: Apache/2.4.51
+ /icons/README - Apache default file found
+ /admin/ - Admin directory found
+ Cookie PHPSESSID created without httponly flag
+ Cookie PHPSESSID created without Secure flag
+ /server-status - Server analysis tool found
+ /docs/ - Directory indexing found
+ Apache/2.4.51 - out of date, known CVEs

```

Gobuster Command:

```
gobuster      dir      -u      https://portal.ssn.edu.in      \
-w /usr/share/wordlists/dirb/common.txt -x php,txt,bak
```

Gobuster Output:

```
=====
Gobuster                                             v3.1.0
=====
/admin (Status: 302) [Size: 214]
/uploads (Status: 200) [Size: 1280]
/backup (Status: 200) [Size: 512]
/server-status (Status: 403) [Size: 199]
/docs (Status: 200) [Size: 3314]
/login.php (Status: 200) [Size: 840]
/phpinfo.php (Status: 200) [Size: 26321]
```

IP Range	Department	Criticality
203.0.113.0/26	Administration	Critical
203.0.113.64/26	CSE Department	High
203.0.113.128/26	ECE Department	Medium
203.0.113.192/26	Student Wi-Fi	Medium
192.168.100.0/24	Internal Mgmt	Critical

8. VULNERABILITY ANALYSIS

Scanning data is analyzed for actual vulnerabilities. Manual verification filters false positives.

Each validated finding receives a CVSS score.

#	Vulnerability	CVSS	Severity
1	SQL Injection	9.8	Critical
2	Cross-Site Scripting	6.1	Medium
3	Weak Passwords	7.5	High
4	Open Ports	5.3	Medium
5	DNS Zone Transfer	5.0	Medium
6	Missing Security Headers	4.0	Low
7	Directory Listing	5.3	Medium
8	Outdated Apache	7.5	High
9	Insecure Cookies	6.5	Medium
10	Broken Authentication	7.5	High
11	Info Disclosure	4.0	Low
12	Misconfiguration	8.0	High
Rating		Range	Action
Critical		9.0-10.0	Immediate
High		7.0-8.9	Within 7 days
Medium		4.0-6.9	Within 30 days
Low		0.1-3.9	Within 90 days

Each finding was scored using CVSS v3.1, which combines several base metrics to produce a number between 0 and 10. Exploitability and impact on confidentiality, integrity, and availability are the major drivers. A finding that is easy to exploit remotely against an internet-facing asset with full data compromise scores far higher than one that requires local access and affects only one account.

Overall risk posture: HIGH. Two critical and four high-severity findings require immediate to short-term remediation.

Severity	Count	Key Findings	Target Window
Critical	2	SQL injection, broken authentication	Immediate
High	4	Weak passwords, outdated Apache, misconfig	7 days
Medium	4	XSS, open ports, insecure cookies, dir listing	30 days
Low	2	Missing headers, info disclosure	90 days

Prioritization follows the CVSS base score combined with business impact: internet-facing hosts and authentication paths are remediated first, while informational and low-severity items are scheduled into regular patching cycles.

9. CONTROLLED EXPLOITATION

Exploitation validates whether vulnerabilities can cause real damage. Every attempt follows: verify manually, select proof-of-concept, execute controlled, document, and clean up. IT admin is notified before high-impact attempts.

9.1 SQL Injection Validation

SQL Injection Proof of Concept:

#	Target:	Student	Portal	Login	(fictional data only)
curl	-X	POST		https://portal.ssn.edu.in/login	\
-d	"username=admin"	OR		'1'='1'	--&password=test"
#		Server			response
HTTP/1.1			200		OK
Set-Cookie:		session=...			HttpOnly
{ "status": "ok", "user": "admin", "role": "administrator" }					

The unauthenticated UNION-based payload returned the application's intended response, confirming that the login parameter was interpolated directly into a SQL query without

parameterization. The proof of concept was executed in a controlled staging copy of the portal and rolled back immediately after capture. No production write was attempted.

Safety measures: timestamped logging, rollback capability, pre-approved payloads only, immediate halt on unintended impact. No destructive payloads used.

10. POST EXPLOITATION

Post-exploitation assesses how deep a compromise can reach.

10.1 Privilege Escalation

The team tests horizontal escalation (accessing other users' resources) and vertical escalation (escalating to admin/root). Common vectors include misconfigured sudo, kernel vulnerabilities, and writable system paths.

Privilege Escalation Session (staging VM):

```
$ whoami
www-data
$ sudo -l
User www-data may run the following commands on portal:
(ALL) NOPASSWD: /usr/bin/systemctl restart httpd
$ sudo systemctl restart httpd
$ id
uid=0 (root) gid=0 (root)
```

The misconfigured sudo rule for the web service account allowed an attacker to restart the web server and, through the service's group membership, obtain a root shell in the staging environment. The same finding was mapped to the production baseline, where the rule was absent, so production was not affected.

10.2 Sensitive Assets and Cleanup

With elevated access, the team maps reachable data: student records, financial logs, transcripts, and config files with embedded credentials. After testing, all artifacts are removed and configurations restored. Evidence is stored encrypted for the reporting phase.

11. REPORTING

The report serves executives needing risk summaries and IT engineers needing specific remediation steps.

Executive Summary: The engagement covered the portal, Moodle, mail and ERP hosts as well as the student Wi-Fi segment. Twelve validated findings were recorded, of which two are critical and four are high severity. No finding required emergency downgrade of service,

and all production data remained intact throughout. The institution's overall risk posture was assessed as HIGH, driven primarily by the SQL injection finding in the student portal.

Tone and structure matter as much as the raw findings. Each vulnerability is reported with a stable identifier, a plain-language description of what it means, evidence collected during testing, and a step-by-step remediation written for the engineers who will execute it. Sensitive evidence such as session tokens and payload details are redacted from the printed copy and kept separate so the document can circulate safely among administrative staff while technical staff receive the full version.

Field		Detail	
Finding ID		VULN-001	
Title		SQL Injection in Student Portal	
Asset		portal.ssn.edu.in/login	
CVSS		9.8 (Critical)	
Impact		Student record compromise	
Remediation		Parameterized queries; WAF	
Timeline		Immediate (48 hours)	
Severity	Count		Priority
Critical	2		Immediate
High	4		Within 7 days
Medium	4		Within 30 days
Low	2		Within 90 days

12. PENETRATION TESTING QUESTIONNAIRE

Before the engagement begins, the client completes a questionnaire that clarifies ownership, constraints, and expectations. The answers shape the scope, the ROE, and the risk register. The full set of thirty questions used for the SSN assessment is listed below.

#	Question
1	Full legal name of the organization?
2	Primary point of contact?
3	Previous penetration tests conducted?
4	Existing cybersecurity policy?
5	Number of servers (physical/virtual)?
6	Operating systems in use?
7	Legacy systems that cannot be patched?
8	Network topology design?

9	Firewall vendor and model?
10	Network segmentation approach?
11	VPN solution for remote access?
12	Wireless authentication method?
13	Web frameworks and languages?
14	Moodle hosting setup?
15	Third-party API integrations?
16	Cloud services in scope?
17	Monitoring tools (SIEM, IDS/IPS)?
18	Compliance requirements?
19	Incident response process?
20	Security awareness programs?
21	Incident response team members?
22	Escalation procedure for critical findings?
23	Systems to exclude from testing?
24	Maintenance blackout periods?
25	Who can terminate the engagement?
26	Preferred report format?
27	Written authorization from all stakeholders?
28	Liability protection for testing team?
29	Pending legal proceedings?
30	Backup and disaster recovery procedures?

13. SECURITY RECOMMENDATIONS

#	Recommendation	Priority	Timeline
1	Parameterized Queries	Critical	Immediate
2	Web Application Firewall	Critical	30 days
3	Multi-Factor Authentication	High	14 days
4	Server Software Updates	High	7 days
5	Strong Password Policy	High	7 days
6	Security Headers	Medium	30 days
7	Disable Directory Listing	Medium	14 days
8	Restrict DNS Zone Transfers	Medium	7 days
9	Network Segmentation	High	60 days
10	Deploy SIEM	High	90 days
11	IDS/IPS Deployment	High	60 days
12	Secure Session Cookies	Medium	14 days

13	Input Validation	High	30 days
14	Quarterly Vuln Scans	Medium	Ongoing
15	Security Awareness Training	Medium	60 days
16	Zero Trust Architecture	High	180 days
17	Backup and Recovery	High	30 days
18	Patch Management Program	High	45 days
19	Incident Response Plan	High	60 days
20	Change Default Credentials	Critical	Immediate

The recommendations are prioritized to minimize residual risk with the least operational disruption. The three critical items are application-layer fixes that directly close the highest-severity findings identified in Section 8 and should be completed before any further testing cycle begins. The high-priority items strengthen authentication and monitoring so that a future compromise is harder to reach and easier to detect once attempted.

Several recommendations carry secondary benefits beyond the immediate finding they address. A web application firewall, for example, does not replace parameterized queries but provides a defense-in-depth layer that blocks many automated attacks at the network edge. Similarly, deploying a SIEM improves visibility for the IT team and supports the compliance reporting requirements the institution is expected to meet for accreditation and grant funding.

14. RISK ASSESSMENT MATRIX

Likelihood / Impact	Low	Medium	High	Critical
High	Medium	High	Critical	Critical
Medium	Low	Medium	High	Critical
Low	Low	Low	Medium	High
Very Low	Info	Low	Low	Medium

SQL Injection: Critical Risk (high likelihood, critical impact). Weak passwords: High Risk. Missing headers: Low Risk. Overall campus risk posture: HIGH.

The matrix uses a qualitative scoring approach common in higher education, where detailed quantitative modeling would require asset value data the institution does not currently capture. Each finding was placed in the matrix by combining the CVSS base score (impact) with an assessment of how easily the affected service can be reached from the internet and how sensitive the underlying data is (likelihood).

The single cell that drives the overall HIGH rating is the SQL injection finding, which sits at the intersection of high likelihood and critical impact because the student portal is openly reachable and holds the most sensitive student records. Reducing that one risk to Low would bring the overall campus posture to Medium, which is why the remediation timeline for that item is the most aggressive in the recommendations.

15. BEST PRACTICES

Adopting industry standards will improve SSN's long-term security posture, aligned with NIST, CIS Controls, and ISO 27001.

15.1 Zero Trust Architecture

Zero Trust operates on 'never trust, always verify.' Every access request requires authentication and authorization regardless of origin. Implementation involves micro-segmentation, strong identity verification, least-privilege access, and continuous traffic monitoring.

15.2 Multi-Factor Authentication

MFA blocks most credential attacks. Even compromised passwords need the second factor. Mandatory for VPN, admin portals, and sensitive data systems. TOTP apps or hardware keys are cost-effective options for educational institutions.

15.3 Network Segmentation and DNS Security

VLANs limit blast radius of any single compromise. A student Wi-Fi breach should not grant admin network access. DNSSEC prevents spoofing. Zone transfer restrictions prevent internal mapping from a single compromised host.

15.4 Logging, SIEM, and Monitoring

A SIEM aggregates logs from firewalls, servers, and endpoints for correlation. This detects multi-stage attacks invisible in individual logs. IDS/IPS adds real-time detection and prevention of known attack patterns.

15.5 Patches, Backups, and Awareness

Formal patch programs define SLAs: critical within 48 hours, high within a week, medium within 30 days. Automated deployment with rollback capability reduces operational burden. Backups follow the 3-2-1 rule: three copies, two different media types, one stored offsite.

Regular recovery tests confirm backups work when needed. Security awareness training covering phishing recognition, password hygiene, safe browsing, and incident reporting creates a human firewall that complements technical controls. Simulated phishing campaigns measure effectiveness over time and identify departments needing additional focus.

16. CONCLUSION

This penetration testing case study on the SSN campus network demonstrates how structured ethical hacking uncovers real security weaknesses in educational environments. The engagement, governed by a detailed ROE, followed seven phases and identified twelve vulnerabilities ranging from critical to low severity.

The most serious findings included SQL injection in the student portal, weak authentication mechanisms, outdated server software, and default credentials on admin interfaces. These issues could enable attackers to steal student records, manipulate academic data, or establish persistent network access. The overall risk posture was assessed as HIGH.

Positives were also noted: the campus firewall blocks unsolicited inbound traffic effectively, Wi-Fi uses enterprise-grade authentication, and the IT team shows awareness of security concerns. These existing controls provide a foundation for recommended improvements.

Twenty recommendations were provided, prioritized by urgency. Critical items require immediate attention. Medium-term network segmentation and SIEM deployment reduce the attack surface. Long-term Zero Trust adoption shifts from perimeter-focused to verify-everything security.

The ROE proved invaluable, preventing scope creep, legal ambiguity, and operational disruption. Every testing activity was traceable back to an authorized action in the agreement, which protected both the testing team and the institution throughout the engagement. This document should serve as a template for future assessments at SSN and other educational institutions in the region.

Moving forward, SSN should establish a recurring penetration testing program with annual comprehensive assessments covering the full network and application stack, quarterly automated vulnerability scans with manual verification, and continuous security monitoring through a deployed SIEM platform. These measures, combined with the recommended security awareness training program and formal incident response procedures, will

significantly strengthen the institution's ability to prevent, detect, and respond to the evolving cyber threat landscape facing educational institutions today.